Universitat Politècnica de Catalunya - BarcelonaTech

Artificial Intelligence and Cybersecurity in IIOT networks

Thesis supervisor

Linus Manubens-Gil

Degree

Master's degree in Machine Learning and Cybersecurity for Internet Connected Systems

Master's thesis

UPC

Chapter 1

Cybersecurity Consulting Framework for Enterprise Firewall Implementation

1.1 Introduction: The Role of Security Consultancy in Network Architecture

The implementation of network security infrastructure is one of the most critical decision areas for enterprise organizations. Although technology specifications and hardware capabilities are critical, the strategic approach to security architecture, policy, and management is what defines the overall effectiveness of the implementation. This is where the importance of the cybersecurity consultant comes in. While a network administrator simply carries out predefined configurations, the cybersecurity consultant has to consider the overall risk profiles of the organisation, identify current vulnerabilities, and recommend appropriate technology and frameworks that align with the overall business strategy.

In the context of the Fortinet NGFW ecosystem, this essentially involves three critical areas:

- Architectural design and network segmentation strategy
- Strategic selection of VPN technology
- Assurance and monitoring strategy

According to industry best practices, the decision to implement a firewall solution should be made in consideration of the overall risk profiles, regulatory requirements, and operational challenges—not solely on technology or cost grounds. This chapter proposes a consulting framework for organisations evaluating or implementing the Fortinet FortiGate firewall solution.

1.2 Architectural Design and Network Segmentation Strategy

1.2.1 The Evolution from Perimeter Defense to Zero Trust Architecture

Traditionally, the approach to network security in enterprise environments has been the "castle and moat" model, where a robust firewall protects an otherwise open interior. Traffic beyond the firewall was considered trusted. Threat intelligence and evolving requirements, however, have forced a paradigm shift.

The primary task is to determine whether the current network architecture aligns with the realities of the modern threat landscape. Modern networks are characterised by:

- **Hybrid cloud computing**, where critical infrastructure spans both cloud and on-premises data centres
- **Remote and mobile employees** accessing the network from untrusted networks
- **Third-party integrations** that may not maintain equivalent security controls
- **Insider threats**, which originate internally and may have unfettered access to the network

As a consultant, the recommendation to use Fortinet NGFW should include a strategic change in the approach to network segmentation and, in many cases, Zero Trust Network Access (ZTNA) principles.

1.2.2 Network Segmentation Implementation Using Fortinet

Network segmentation divides the corporate network into smaller zones. FortiGate firewalls enable this through several mechanisms.

Internal Security Domains (VDOMs)

FortiGate firewalls offer Virtual Domains (VDOMs), allowing a single physical firewall to function as multiple logical firewalls. Key advantages include:

- **Separation of duties:** Different departments maintain independent security policies.
- **Reduced blast radius:** Compromise of one domain does not imply access to others.
- **Regulatory isolation:** Entities under different compliance frameworks maintain isolated environments.

Recommended Zone Architecture

DMZ (Demilitarised Zone) Contains publicly accessible services (web servers, mail servers, DNS). Access to the internal network from the DMZ should be restricted.

Internal Corporate Network Houses employee workstations and common business applications.

Sensitive/Restricted Zone Dedicated to sensitive services such as databases, financial systems, and executive servers. Access restricted to authorised personnel.

Guest/Contractor Network Isolated for temporary users who do not require corporate network access.

Management Network Isolated for network infrastructure management via bastion hosts.

1.2.3 Zero Trust Network Access (ZTNA): The Modern Consulting Recommendation

The traditional VPN model assumes: *"if you're connected to the VPN, you're trusted."* The Zero Trust model rejects this, applying the principle: *"never trust, always verify."* With ZTNA, every access attempt - whether from inside or outside the network - is subject to both authentication and authorisation. Fortinet implements ZTNA through its FortiGate appliances and dedicated ZTNA product line.

1.2.3.0.1 ZTNA is particularly suitable in the following scenarios:

- High volume of remote access users
- Large volume of third-party access
- Regulatory requirements for strict access control
- Previous security incidents involving compromised credentials

1.2.3.0.2 Phased ZTNA Implementation:

Phase 1 (Months 1 - 3) ZTNA for high-risk applications

Phase 2 (Months 4 - 6) ZTNA for standard business applications

Phase 3 (Months 7 - 12) ZTNA across the entire organisation

1.3 Strategic Selection of VPN Technologies: SSL vs IPsec

1.3.1 Comparative Analysis and Decision Framework

One of the most critical decisions in firewall implementation projects is the choice between SSL VPN and IPsec VPN. Both are supported by FortiGate appliances but have distinct performance and usage characteristics.

Table 1.1: Comparative Analysis of SSL VPN vs IPsec VPN

Criteria	SSL VPN	IPsec VPN	Consulting Recommendation
Primary Use Case	Remote access for individual users	Site-to-site VPN; high-volume remote access	SSL VPN for small deployments; IPsec for site-to-site and large-scale environments
Client Requirements	Web browser or FortiClient	FortiClient or third-party IPsec clients	SSL for non-technical users; IPsec for technical users
Connection Establishment	TCP port 443	UDP ports 500, 4500	SSL for restricted firewalls; IPsec for stable connections
Performance Impact	More CPU-intensive; performance may degrade at high concurrency (500+ users)	Hardware-accelerated; minimal impact	IPsec preferred; SSL for web-based access
Firewall Traversal	Excellent (standard HTTPS port)	May require NAT-T	SSL for restricted environments
Configuration Complexity	Simple (server-side only)	Complex (client-side required)	SSL for rapid deployment; IPsec for standardisation
Network Visibility	Limited	Full packet-level inspection	IPsec preferred for monitoring and reporting
Encryption Strength	Strong (TLS 1.2/1.3)	Very strong (configurable)	Both acceptable; IPsec preferred for legacy compatibility

1.3.2 Consulting Framework: Decision-Making Methodology

Step 1: Define Use Case and User Profile Is this for remote access or site-to-site VPNs? How many concurrent connections are expected? What is the technical level of end users? Will they connect from managed or unmanaged environments?

Step 2: Assess Environmental Constraints What network environments will users be in (public Wi-Fi networks such as hotels and airports, 4G/5G)? Are there protocol requirements for regulatory compliance? How much performance degradation is acceptable?

Step 3: Evaluate Implementation Complexity What is the IT team's capacity for ongoing management? Is rapid deployment required? Is standardisation across multiple offices a priority?

Step 4: Make Recommendation with Justification

Scenario A - Remote Individual Users (0 - 200 users)
Recommendation: SSL VPN
Justification: Low infrastructure requirements, no client deployment issues, excellent firewall traversal, rapid deployment
Implementation: FortiClient for corporate devices, browser-based for others, MFA for all users
Expected outcome: Reduced IT support overhead, simplified onboarding for non-technical users, and faster deployment compared to IPsec-based solutions

Scenario B — Site-to-Site Branch Connectivity
Recommendation: IPsec VPN
Justification: Performance predictability, hardware offload, standardisation, full traffic inspection
Implementation: Standardise IPsec across all offices, FortiManager for centralised management, redundant tunnels
Expected outcome: Consistent and predictable throughput per tunnel, with performance levels dependent on the FortiGate hardware model and configured encryption algorithms

Scenario C - Large Remote Workforce (500+ concurrent users)
Recommendation: Hybrid approach
Justification: SSL VPN for contractors and BYOD; IPsec for standardised corporate endpoints
Implementation: Both solutions on the same FortiGate, segmented policies per tunnel type
Expected outcome: Flexibility, high control, acceptable performance for both tunnel types

1.3.3 SSL VPN: Detailed Consulting Considerations

Performance Optimisation

- Monitor CPU utilisation at expected peak load.
- Plan capacity with 70 - 80% CPU as maximum allowable.
- Implement hardware load balancing if CPU exceeds 60% during peak hours.

Security Hardening

- Disable TLS versions prior to 1.2.
- Implement Multi-Factor Authentication (MFA) for all SSL VPN users.
- Apply geographic IP restrictions.
- Enforce session timeout policies (disconnect idle users after 30 minutes).
- Log all SSL VPN connection events.

User Experience

- Provide guidance for FortiClient installation and troubleshooting.
- Establish support procedures for connection failures.
- Communicate browser requirements (Enable JavaScript, Use Chrome or Edge, Allow cookies, etc.).

1.3.4 IPsec VPN: Detailed Consulting Considerations

Route-Based vs Policy-Based Configuration

Policy-Based IPsec (Legacy) Access control handled through firewall policies.

Route-Based IPsec (Recommended) Traffic passes through virtual tunnel interfaces, enabling dynamic routing and greater flexibility.

Consulting recommendation: Use route-based configuration for all new IPsec deployments.

High Availability and Redundancy

- Establish dual IPsec tunnels to the same remote site.
- Use independent circuit providers for geographic redundancy.
- Enable automatic tunnel failover with sub-second recovery.
- Use Dead Peer Detection (DPD) to quickly identify failed tunnels.

Encryption Algorithm Selection

- **Phase 1 (IKE):** AES-256 with SHA-384
- **Phase 2 (IPsec):** AES-256 with SHA-384
- **DH Groups:** Group 14 or higher for Phase 1; Group 20 or higher for Phase 2
- Avoid legacy algorithms (3DES, MD5) unless required for compatibility.

1.4 Compliance Assurance and Continuous Security Monitoring

1.4.1 The Consultant's Role in Regulatory Compliance

Firewalls play a role in organisational compliance that extends beyond network protection. Frameworks such as ISO 27001, PCI-DSS, HIPAA, and GDPR require organisations to demonstrate controlled access, continuous monitoring, and effective incident detection.

Compliance Gap Analysis

Before implementation, consultants should compare current security controls against regulatory requirements:

- Are network access events currently logged?
- Are logs retained for the required period (typically one to three years)?
- Are logs protected from unauthorised modification?
- Can auditors review audit trails without affecting active investigations?

Policy Design to Support Compliance

PCI-DSS Requirement 1 Establish firewall configuration standards to restrict unnecessary access to cardholder data environments.

ISO 27001 A.13.1.1 Monitor system access for unauthorised attempts.

1.4.2 FortiAnalyzer: The Foundation of Security Visibility

FortiAnalyzer centralises and analyses security events across the Fortinet ecosystem. Consultants should address three key requirements during deployment.

Event Aggregation and Log Retention

- Retain logs for at least one year, or three years for healthcare environments.
- Automate archival to secure long-term storage.
- Ensure reliable power and redundant connectivity to prevent log loss.

Real-Time Alerting and Threat Detection

High Priority Malware detections or IPS alerts on critical systems

Medium Priority Unusual traffic patterns, policy violations, repeated failed logins

Low Priority Informational events such as successful VPN connections

Alerts should escalate automatically via email, SMS, or SIEM integration.

Compliance Reporting and Audit Preparation

FortiAnalyzer supports the following standard report types:

- **Network Access Report:** User access details and activities
- **Firewall Policy Change Report:** Configuration changes and responsible administrators
- **Security Events Report:** Detected threats and responses
- **VPN Usage Report:** Authentication and session information

1.4.3 SSL Inspection Strategy and Privacy Considerations

SSL/TLS inspection (decrypting encrypted traffic for deep inspection) involves trade-offs across three dimensions.

Security Perspective Without inspection, firewalls cannot detect malware via HTTPS, data exfiltration, unauthorised cloud application usage, or command-and-control communications.

Privacy and Legal Perspective Users expect HTTPS traffic to remain private. Decryption may conflict with privacy expectations or legal restrictions in some jurisdictions.

Performance Perspective SSL inspection can reduce firewall throughput by 30 - 50%, even with hardware acceleration.

Balanced Consulting Recommendation

Mandatory Inspection General web traffic and high-risk services (cloud storage, collaboration platforms)

No Inspection Banking, healthcare portals, government services, personal email

Restricted Inspection Monitor traffic patterns for VPN or peer-to-peer applications without decrypting content

User Notification Inform users that network activity may be monitored

Policy Review Quarterly review of inspection exceptions; annual privacy and performance assessment

1.5 Implementation Roadmap: From Strategy to Operations

1.5.1 Phased Implementation Approach

Phase 1 (Months 1 - 2): Planning and Assessment
infrastructure and application inventory, threat and risk assessment, compliance gap analysis, recommendation report

Phase 2 (Months 2 - 3): Design and Procurement
Detailed network architecture design, hardware sizing and capacity planning, procurement of FortiGate and FortiAnalyzer, physical infrastructure preparation

Phase 3 (Months 3 - 5): Initial Implementation and Testing
Deploy firewall in monitoring/permissive mode, implement segmentation and baseline policies, deploy FortiAnalyzer logging, conduct testing to identify policy issues

Phase 4 (Months 5 - 7): Production Cutover and Optimisation
Transition to enforcement mode, deploy VPN services, implement IPS policies, monitor performance and refine configurations

Phase 5 (Months 7 - 12): Maturity and Continuous Improvement
Establish incident response processes, implement compliance monitoring, conduct quarterly policy reviews, plan for ZTNA and advanced technologies

1.5.2 Change Management and Stakeholder Communication

Firewall deployments affect multiple teams and users. Consultants should implement structured communication:

- Weekly updates to security leadership
- Monthly updates to the broader IT team
- Quarterly executive-level impact reports

Escalation procedures should allow application teams to report connectivity issues quickly. A formal process for firewall policy exception requests, supported by justification. Comprehensive documentation and training must be provided to IT staff responsible for managing the system.

1.6 Conclusion: The Value of Security Consulting

Deploying a Next-Generation Firewall such as Fortinet FortiGate represents a major investment in organisational security. The full value of this investment is realised only when guided by skilled cybersecurity consulting.

by:

- Transforms business needs into technical architecture
- Evaluates trade-offs such as SSL versus IPsec VPN strategies
- Develops policies that balance security and operational usability
- Implements frameworks for monitoring, compliance, and continuous improvement
- Creates roadmaps that strengthen security while minimising disruption

Organisations that follow these guidelines and work with qualified consultants can build a strong and resilient security posture capable of adapting to evolving cyber threats.